

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On December 16, 2020, a complaint was received by this Spanish Agency for Data Protection (hereinafter AEPD), submitted by A.A.A. against ILUNION SEGURIDAD, S.A. with NIF A78917465.

In particular, due to the following circumstances:

The complainant stated in the initial complaint that labor communications were sent to personal phones without having given their consent or having the participation of the workers' representation, and that personal email addresses of the workers were revealed by sending emails without using the blind carbon copy option to all recipients of the email.

Along with their complaint, the complainant provided copies of two emails sent to several recipients without using the blind carbon copy option, as well as copies of instant messages from the WhatsApp application received by the complainant and other workers and sent by the company where they provide their services.

Finally, the complainant alleges in their initial complaint that at no time have they given their consent to be included in instant messaging communication groups on the WhatsApp application created by the coordination of the Fuerteventura airport service, nor to receive labor-related emails without the blind carbon copy option being used by the senders, which has resulted in their email address being disclosed to other workers without their consent.

SECOND: In accordance with the preliminary mechanism for the admission of complaints submitted to the AEPD, as provided in Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), which consists of forwarding them to the Data Protection Delegates designated by the data controllers or processors, or to them when they have not designated any, and for the purpose indicated in the aforementioned article, the complaint was forwarded to ILUNION SEGURIDAD, S.A. (hereinafter, the complained party) for analysis and response within one month, which was verified by a document dated March 4, 2021, received by this Agency.

THIRD: On April 15, 2021, after analyzing the documentation in the file, a resolution was issued by the director of the Spanish Agency for Data Protection, agreeing to archive the complaint.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/22

The resolution was notified to the complaining party on April 15, 2021, through the Electronic Notification Service and Enabled Electronic Address as certified in the file.

FOURTH: On April 22, 2021, the complaining party filed an optional appeal for reconsideration (RR/00267/2021) through the Electronic Registry of the AEPD, against the resolution issued in the proceedings E/00631/2021, in which they express their disagreement with the contested resolution, arguing that the fact of not having expressed disagreement with the processing of personal data does not authorize the responding party to use personal data such as personal email or private phone number, not corporate, for the communications made.

Furthermore, they add that the communications made via the WhatsApp messaging service were not due to an ERTE (Temporary Employment Regulation File), but for the organization of work shifts communicated outside of working hours, and the fact that workers perform their work outside does not imply that communications must be made to personal mobile phones since the responding party has a physical office at the workplace.

FIFTH: After analyzing the allegations of the complaining party in RR/00267/2021, on July 30, 2021, the Director of the Spanish Agency for Data Protection resolves to uphold said appeal for

reconsideration, thus initiating the sanctioning procedure PS/00456/2021, notified to the respondent on November 11, 2021.

SIXTH: Throughout the sanctioning procedure PS/00456/2021, the responding entity claims to have suffered defenselessness in the appeal for reconsideration (RR/00267/2021) filed by the complainant before this Agency, denouncing the facts subject to the present procedure, which led to its acceptance and the corresponding initiation of the sanctioning procedure PS/00456/2021.

The responding entity claims that it was not informed of the filing of said optional appeal for reconsideration filed by the complainant before the Agency, and therefore could not defend itself.

In light of this, in accordance with Article 118 of Law 39/2015 of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), which regulates the right to a hearing for interested parties, this Agency decides to archive the sanctioning procedure PS/00456/2021 and revert its actions to the moment when the hearing procedure was omitted in the optional appeal for reconsideration (RR/00267/2021), in accordance with Article 119.2 of the LPACAP.

SEVENTH: On March 15, 2022, the appeal filed was sent to the responding party within the framework established in Article 118 of the LPACAP for the purpose of allowing them to formulate allegations and present the documents and evidence they deemed appropriate. The notification of the hearing procedure occurred on March 17, 2021, through the Electronic Notification Service and Enabled Electronic Address, as certified in the file.

EIGHTH: On March 31, 2022, the responding party submitted allegations to the appeal for reconsideration filed, arguing that the security services...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/22

private services provided by ILUNION SEGURIDAD, S.A., are generally dislocated, and in order to keep workers informed about essential circumstances of their employment relationship, such as their shifts, replacements, vacations, occupational risk prevention, training, etc., it is necessary to maintain agile and effective communication channels based on telephone or email, as communication by postal mail is impossible given the time it requires. On the other hand, it states that sometimes it may be necessary for information to be shared among several workers, so that all of them know that others are also informed about the same, and to resolve general doubts. To this end, on 22/11/2019, the WhatsApp group "****GRUPO.1" was created, with the phone numbers of a small group of workers, which they had already provided to the company as contact details, as well as their email, within the framework of their employment relationship. This group is only used for matters related to the employment relationship, that is, for the formation of this group of workers. At no time is it used to give daily work instructions, assign tasks, etc.

It expresses that the workers are in agreement with the communication channel thus established, participating in it, which is proof of active behavior in accepting that their phone number is used in the WhatsApp group. It adds that except for the creation of this group, the rest of the communications occur via WhatsApp individually. In all individual WhatsApp communications provided by the complainant, it can be observed that the worker actively participates, thereby accepting the established means of communication, and consequently, the processing of their personal data of their phone in this manner.

It states that WhatsApp messages became more frequent starting in March 2020, the date when confinement due to the pandemic was declared, which made sending messages via WhatsApp the most suitable way to convey last-minute changes in order to maintain a critical service at that time, such as airport surveillance, and due to the existing ERTE situation at that time, which made continuous reassignment of work shifts necessary.

It grounds the basis of legitimacy for the use of the mobile phone number on what is established in Article 6.1, paragraphs a), b), and f) of the GDPR due to the existence of a contractual relationship and a legitimate interest.

It argues that the workers consented to the processing of the data, both in the group mode in which each accessed the phone data of others, as well as in individual communication; that the processing is also covered by Article 6.1.b) of the GDPR as derived from the resolution of the AEPD R/00026/2021 and SAN 2087/2020, of July 29; and that there was a legitimate interest, in accordance with what is provided in Article 6.1.f) GDPR, in processing said data in light of the necessity caused by the pandemic.

Finally, it alleges the lack of culpability of the entity and explains that in order to prevent similar incidents from occurring, ILUNION SEGURIDAD, S.A., made the decision to adopt the measure of sending a communication to all its managers.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/22

intermediate in order to remind that in ILUNION SEGURIDAD, S.A. both the creation of WhatsApp groups with the personal phone numbers of employees and the sending of emails without using the blind carbon copy (BCC) option to the personal email addresses of said employees are prohibited. Additionally, the guidelines governing the responsible use of instant messaging applications such as WhatsApp in ILUNION have been attached for reminder purposes.

NINTH: On August 8, 2022, the Director of the Spanish Agency for Data Protection upheld the appeal for reconsideration filed by A.A.A. against the resolution of this Agency issued on April 15, 2021, which agreed to archive the complaint related to ILUNION SEGURIDAD, S.A.

TENTH: On September 20, 2022, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the complained party, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Articles 83.5 and 83.4 of the GDPR.

ELEVENTH: After the aforementioned initiation agreement was notified in accordance with the rules established in the LPACAP, the complained party submitted a written statement in which it reiterates that communications via WhatsApp or email are used solely for matters related to the employment relationship, that is, for training, sick leave, COVID information, determination of shifts resulting from the COVID ERTE, days off, etc., and sometimes it may be necessary for the information to be shared among several employees, so that all of them are aware that others are informed of the same, and to resolve general doubts.

The complained entity insists that WhatsApp is never used to give daily work instructions, assign tasks, etc., also noting that the information shared, if not channeled through phone or email, would have had to be sent by postal mail to each employee's home, which is an absolutely inefficient means. Furthermore, it argues that the employees are in agreement with the communication channels thus established, participating in them, or even initiating them themselves, which is proof of active behavior in accepting that their contact data (phone number, email, etc.) be used for this purpose.

The entity explains that WhatsApp messages became more frequent starting in March 2020, as well as the emails provided, with many of these communications being COVID-related, as they refer both to preventive measures, the ERTE, and protocols established by the Airport. The communications via WhatsApp and email are almost entirely derived from the force majeure ERTE situation, due to the decrease in the number of travelers at the Airport, caused by the COVID pandemic.

It states that there is no evidence that the coordinator created a WhatsApp group with the personal phones of 5 employees, as the evidence provided by the complainant shows that people from the chat participate, from the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid
sedeagpd.gob.es
5/22

that initially none of them is the complainant. The supposed workers comprising the group (5 people) are also not identified, so it is unknown whether they are or are not employees of the company, and whether the alleged coordinator had their consent to create the group, that is, to share phone numbers among all its members. In this regard, it is very revealing that the names of the individuals in that chat do not even match the names of the individuals who sign the complaint along with the complainant.

As for the complaining party, the respondent specifies that the worker's consent to process their mobile phone number for communication via WhatsApp regarding aspects related to their employment relationship is clear, and that they neither expressed their disagreement with the processing of their personal data nor exercised their rights at any time before ILUNION SEGURIDAD, S.A., in accordance with the GDPR. There were also no workers who exercised their rights during the time the messaging platform was used or who blocked the chat.

It indicates that this processing may also be justified by the necessity for the execution of an employment contract in which the interested party is a part and, subsidiarily, by the necessity of such processing for the satisfaction of legitimate interests pursued by ILUNION SEGURIDAD, S.A., in accordance with the provisions of Article 6.1.b) and f) of the GDPR. In this context, it cites in its defense the resolution R/00026/2021 of the AEPD and the SAN 2087/2020, of July 29.

It reiterates that as soon as it became aware of the allegations through the request (E/00631/2021) dated 02/02/2021, in order to prevent similar incidents from occurring, ILUNION SEGURIDAD, S.A., decided to adopt the measure of sending a communication to all its middle management to remind them that in ILUNION SEGURIDAD, S.A., both the creation of WhatsApp groups using the personal phone numbers of workers and the sending of emails without using the blind copy (BCC) option to the personal email addresses of those workers are prohibited, and that, additionally, the guidelines governing the responsible use of instant messaging applications such as WhatsApp have been provided for reminder purposes.

TWELFTH: On October 6, 2022, the instructor of the procedure agreed to reproduce for evidentiary purposes the complaint filed by A.A.A. and its documentation, as well as the documents obtained and generated during the admission phase of the complaint.

Likewise, the allegations against the initiation of the referenced sanctioning procedure presented by ILUNION SEGURIDAD, S.A., and the accompanying documentation are reproduced for evidentiary purposes.

THIRTEENTH: On November 8, 2022, a resolution proposal was made, proposing the following:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

6/22

That the Director of the Spanish Agency for Data Protection sanctions ILUNION SEGURIDAD, S.A., with NIF A78917465, for an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, with a fine of €100,000 (one hundred thousand euros).

That the Director of the Spanish Agency for Data Protection sanctions ILUNION SEGURIDAD, S.A., with NIF A78917465, for an infringement of Article 32 of the GDPR, classified under Article 83.5 of the GDPR, with a fine of €50,000 (fifty thousand euros).

FOURTEENTH: According to the report obtained from the AXESOR tool, the entity ILUNION SEGURIDAD, S.A. is a large company, established in 1988, with a turnover of ***AMOUNT.1 € in 2021.

From the actions carried out in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: Labor communications have been sent by email without using the blind copy option, revealing the personal email addresses of the workers to all recipients of the emails.

LEGAL GROUNDS

I

Competence

According to the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Security Breach

Article 4.12 of the GDPR establishes that a "personal data breach is considered to be any breach of security that results in the accidental or unlawful destruction, loss, alteration of, or unauthorized access to personal data transmitted, stored, or otherwise processed."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/22

In the present case, there is a breach of personal data security under the circumstances indicated above, categorized as a breach of confidentiality. It should be noted that the identification of a security breach does not imply the direct imposition of a sanction by this Agency, as it is necessary to analyze the diligence of those responsible and in charge, as well as the security measures applied.

III

On the infringement of Article 5.1 f) of the GDPR

The communication of personal data of a worker to other workers of the company implies the processing of personal data and requires legitimization for such communication to occur lawfully; therefore, it will be necessary to analyze in each case whether there is a legal basis for the employer to share personal information of the workers, taking into account the intended purpose and the data processed.

The entity being claimed states that there is consent from the workers for the use of such contact means, considering that there is a clear affirmative action from the workers that would legitimize its use.

On this particular matter, it should be indicated, beforehand, that there is no doubt that it is necessary for the execution of the contract for the employer to have some means of communication with the workers, which could include the use of instant messaging or email. The employer can use a corporate means provided by him for communication with the workers of his company and could also use the personal means that the worker has voluntarily communicated to the company, given that there is no doubt that workers can voluntarily provide their phone number or email address as a means of communication with the employer regarding work-related matters, as long as it is not an obligation imposed by the employer.

This issue is addressed in the Agency's Guide on "Data protection in labor relations" in the following terms:

"(...) In general, it seems necessary for the execution of the contract that the employer has some means of communication with the workers, and it is essential that the worker provides the company with some form of contact. However, the employment contract does not legitimize the company to request all that data from the worker, as the Supreme Court has pointed out regarding the email

address or personal phone number (STS 4086/2015, of September 21, Social Chamber). That is to say, the necessity of the processing must be weighed on a case-by-case basis.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/22

To this end, it will be necessary to analyze in each case the legal basis alleged – which could be the employment contract, consent, or the legitimate interest of the employer – the intended purpose, and the data processed."

Therefore, it will be necessary to take into account the purpose pursued by the employer and the data processed in each case in order to determine whether in a specific case the processing can be based on any of the bases contained in Article 6 of the GDPR, which in this context could be those contemplated in letters a), b), and f) of Article 6.1 of the GDPR. Regarding the adequacy of these bases of legitimacy to legitimize the employer's use of instant messaging services or email, the following considerations can be made:

a) Regarding consent, it can be stated that when the worker voluntarily communicates with the employer through their personal mobile phone or personal email address, there exists a "clear affirmative act" of their consent to receive communications about work-related matters through such means, as declared by the Superior Court of Justice of Asturias, Social Chamber, in its ruling of April 12, 2022, provided that the use of this personal data by the employer is not imposed in the employment contract, as determined by the Supreme Court in the aforementioned Judgment 4086/2015, of September 21, Social Chamber, since in such a case the worker does not provide their "voluntary" consent as explained in the aforementioned ruling: "(...) given that the worker is the weaker party in the contract, the possibility that this contractual weakness could vitiate their consent to a business provision related to a fundamental right must be excluded, and given the circumstances – it is about the moment of access to a scarce good such as employment – it can well be understood that consent on such an extreme is not completely free and voluntary (...)."

In this context, when the employer uses the personal contact data of employees and shares it with other workers, whether by email or through instant messaging, as a "necessary" means for the development of the existing contractual relationship between employees and the company, the processing of this data cannot be based on consent, since consent should not be considered freely given when the interested party does not have true or free choice or cannot deny or withdraw their consent without suffering any detriment (consideration 42). The employee must be able to deny or withdraw consent without suffering any detriment, which prevents this basis of legitimacy from being the appropriate one to substantiate such processing for this purpose, as the dynamics of the employment relationship would depend on whether the employee freely consented to the processing or not.

b) When sharing information about work matters is "necessary" for the execution of the employment contract signed by the worker and the employer uses corporate means for this, the processing of personal information may be covered by the legitimacy basis contemplated in Article 6.1.b) of the GDPR. However, in these cases, it will be essential that the information shared is adequate, relevant, and limited to what is necessary in relation to the purposes pursued, as required by the principle of data minimization, as well as the establishment of appropriate technical and organizational measures to prevent access.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/22

not authorized to the personal information that is shared, in order not to undermine the principle of integrity and confidentiality established in Article 5.1.f) of the GDPR.

In this regard, we stated in the resolution of file EXP202105690, which archived the complaint of a

worker regarding the creation of two WhatsApp groups and their inclusion in them by the employer, where personal data related to delivery routes, the individuals performing them, the hours, the location of the vans at the end of the workday, and various information are published, that "the data subject to processing are the minimum necessary for the organization of the specific work carried out by the respondent party, which has informed the workers of the purpose of the processing in the WhatsApp groups created for the purpose of using this communication channel for matters related to the employment contract, working conditions, organization and development of work and delivery tasks while maintaining confidentiality about them."

However, the worker has the right to maintain control over the personal data that concerns them; therefore, when the contact data used by the employer is not corporate but rather personal use of the workers, the processing of such data, including its disclosure to other colleagues, cannot be justified on the basis of the legal basis contemplated in Article 6.1.b) of the GDPR.

The National Court, social chamber, in its ruling of June 27, 2022, summarizes the doctrine established by the chamber itself and by the Supreme Court as follows:

1.- It is doctrine of both this Chamber and Chamber IV of the Supreme Court; the alienation inherent in the employment contract (per Article 1.1 of the Workers' Statute) implies, among other things, the alienation in the means, which means that it is the employer who must provide the worker with the necessary means for the development of their employment relationship (Supreme Court ruling of 8-2-2021 - rec 84/2019 - confirming National Court ruling of 6-2-2019 - proc.318/2018; National Court ruling of 10-5-2021 - autos 105/2021).

2.- On the other hand, the Supreme Court ruling of 21-9-2015 - rec 259/2014 - confirming the National Court ruling of 28-1-2014 - autos 428/2013 - considered it contrary to the then applicable national and European regulations on data protection for the worker to be obliged to provide their personal email and phone number to the company, reasoning that if they were essential for the development of the contract, both should be provided by the company to the worker.

This criterion is also followed in the FAQ of the AEPD: Can the employer request the worker's personal phone number and email address?

"The processing of the worker's personal email and phone number can be disregarded by the employer, given that no regulation requires the worker, for the proper perfection of their contractual relationship, to provide these data to the employer to whom they render services.

That is to say, such processing would exceed what is initially permitted by data protection regulations, and more specifically, the legitimacy of Article 6 of the GDPR based on the execution of a contract.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/22

However, if the circumstances of the provision of services for the company required the personal availability of the worker outside of their workplace or working hours, a more moderate and equally effective measure to achieve communication between the company and the worker would be to provide the worker with a work instrument such as a company phone.

In any case, it would be possible for those affected to provide their personal email and phone number, although the collection of this data would have to be voluntary, prior to obtaining the consent of the worker, who may subsequently oppose its processing by exercising their rights of opposition or deletion.

In short, the processing of the worker's personal phone number or their personal email address for the purpose of maintaining the employment relationship cannot be considered "necessary" for the execution of the contract, as required by Article 6.1.b) of the GDPR, in the sense that the main object of the specific contract with the data subject cannot be achieved if the specific processing of the personal data in question is not carried out (Guidelines 2/2019 on the processing of personal data under Article 6(1)(b) of the GDPR in the context of the provision of online services to data subjects), since the employer can always provide these necessary means to the workers.

Consequently, in general terms, this use cannot be justified on the basis of the legal ground

contemplated in Article 6.1.b) of the GDPR.

c) Finally, it remains to be analyzed whether the applicable legal ground could be legitimate interest. In relation to this legal basis of legitimate interest, Article 6.1.f) of the GDPR considers the processing to be lawful when "it is necessary for the satisfaction of legitimate interests pursued by the data controller or by a third party, provided that such interests do not prevail over the interests or the rights and fundamental freedoms of the data subject which require the protection of personal data (...)". Recital 47 of the GDPR specifies the content and scope of this legitimizing basis for processing: "(47) The legitimate interest of a data controller, including that of a controller to whom personal data may be communicated, or of a third party, may constitute a legal basis for processing, provided that the interests or the rights and freedoms of the data subject do not prevail, taking into account the reasonable expectations of the data subjects based on their relationship with the controller. Such legitimate interest could arise, for example, when there is a relevant and appropriate relationship between the data subject and the controller, such as in situations where the data subject is a customer or is in the service of the controller. In any case, the existence of a legitimate interest would require a meticulous assessment, including whether a data subject can reasonably foresee, at the time and in the context of the collection of personal data, that such processing may occur for that purpose. In particular, the interests and fundamental rights of the data subject could prevail over the interests of the data controller when processing is carried out."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/22

Processing of personal data in circumstances where the data subject does not reasonably expect further processing to take place. Since it is the legislator's responsibility to establish by law the legal basis for the processing of personal data by public authorities, this legal basis should not apply to the processing carried out by public authorities in the exercise of their functions. The processing of personal data strictly necessary for the prevention of fraud also constitutes a legitimate interest of the data controller concerned. The processing of personal data for direct marketing purposes may be considered to be carried out for legitimate interest.

It is also important to highlight that public authorities in the exercise of their functions cannot base their processing on this legal basis.

The legitimate interest of the employer could be an appropriate basis in a labor context, as recognized by the Article 29 Working Party in its Opinion 6/2014 on the concept of legitimate interest of the data controller under Article 7 of Directive 95/46/EC, considering that it could be lawful under Article 7, letter f) of the Directive: "The creation of an internal database of contact details of the employees of a company containing the name, work address, telephone number, and email address of all employees, to allow employees to contact their coworkers (...) if it is demonstrated that the interest of the data controller prevails and all appropriate measures are taken, including, for example, consultation with employee representatives."

According to the doctrine of the Court of Justice of the European Union, as established in the Judgment of July 29, 2019 (Case C-40/17, "Fashion ID"), this legal basis requires the concurrence of three cumulative requirements, namely (i) that the data controller or the third party or parties to whom the data are communicated pursue a legitimate interest; (ii) that the processing of personal data is "necessary" for the satisfaction of the legitimate interest pursued; and (iii) that the fundamental rights and freedoms of the data subject do not prevail, for which it will be necessary for the controller to carry out a balancing test between the pursued interest and the interests or rights and freedoms of the data subjects.

Thus, it must be taken into account, in any case, when analyzing whether this legal basis contemplated in Article 6.1.f) of the GDPR can legitimize a specific processing, that there must be a fair balance between the right to the protection of personal data of workers and the interests of the employer, so that the employer's use of personal data passes the proportionality test, which must be observed in any restrictive measure of a fundamental right in its triple manifestation of suitability,

necessity, and proportionality in the strict sense. In particular, for the processing to pass the necessity test, it will be essential that it was not possible to use a less invasive communication system than the one used.

There is no doubt that there is a conflict between the employer's right and the employees' right to the protection of their personal data that requires a

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/22

fair weighting between the need to protect employee privacy and the employer's right to ensure the proper functioning of the company

In this regard, the special circumstances that occurred during the validity of the state of alarm declared in our country by Royal Decree 4463/2020 of March 14, 2020, cannot be overlooked.

In our resolution R/00026/2021 of 01/14/2021, taking into account such circumstances, we stated the following:

"(...) it should be noted that communication methods are constantly changing and companies seek and use simple, fluid, agile, effective, and economical organizational and planning tools, with the advantages that this entails for establishing communication with their employees, allowing for a correct and efficient functioning of the company.

The use of mobile devices and their tools, email, or other telematic devices or channels, becomes essential for those employees who carry out their functions outside the workplace, as in the case at hand. Therefore, the parties must agree to seek agile communication channels, given that communication via postal mail may not be operational in the context of the employment relationship with the claimant (especially considering the health emergency due to Covid-19), except for the sending of payrolls or communications that do not require a punctual and immediate action."

In this line of thought, it is also worth mentioning the ruling 2087/2020, of July 29, from the National Court, which addresses, in its eighth foundation, the legality of the communication mechanism used by the company to inform workers, due to the impossibility of delivering the communication in person, as a result of the isolations imposed by the health crisis caused by SARS-CoV-2, with the following pronouncement:

"EIGHTH: As a final point of criticism, the acting union questions the communication mechanism used by the company to inform the affected workers of its final decision, as the use of different applications and networks allows for the free circulation of information in a non-authentic manner.

The reason cannot be favorably accepted for various reasons. First, because the acting union does not deny that the workers who were ultimately affected by the measure in question did not receive the company communication in an authentic manner, but rather generically asserts that 'WhatsApp, email, and other similar applications allow for the circulation of information anonymously.' However, this circumstance has not been verified in the case being judged, where the company has provided different emails sent from a company domain (the authenticity of which is not in doubt, as the acting party acknowledged all documents submitted otherwise) to workers affected by the ERTE. In fact, it can be..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/22

It is verified, as in the case of Mr. Eleuterio (pages 8 and 9 of descriptor 134), that the signature of the worker himself is present in the corresponding box, which evidences the effective receipt of the document.

On the other hand, we must not forget the particular circumstances surrounding the processing of the ERTE in question, with a state of alarm declared by Royal Decree 4463/2020 of March 14, 2020, whose Article 7 limited the freedom of movement of individuals, allowing them to circulate only on

public roads for the following activities: a) Acquisition of food, pharmaceutical products, and essential goods. b) Assistance to health centers, services, and establishments. c) Travel to the workplace to perform their labor, professional, or business duties. d) Return to the habitual place of residence. e) Assistance and care for the elderly, minors, dependents, persons with disabilities, or particularly vulnerable individuals. f) Travel to financial and insurance entities. g) Due to force majeure or a situation of necessity. h) Any other activity of a similar nature that must be carried out individually, unless accompanied by persons with disabilities or for another justified reason.

In short, considering that Article 3.1 of the Civil Code states that we must interpret the norms according to the social reality of the time in which they are to be applied, never have circumstances been so determinative to allow deviation from what are the ordinary habits and practices in communications between employer and employee, such that we must consider that the means employed by the defendant to inform the workers about their inclusion in the ERTE due to force majeure was an adequate system given the concurrent circumstances at that time, with no evidence that through such a communication channel the fundamental rights of workers' privacy were not safeguarded, nor was the authenticity and veracity of what was communicated guaranteed.

The claim, therefore, must be dismissed."

However, the considerations presented cannot exempt the employer from justifying the "necessity of the measure" and from conducting a fair balancing of the interests involved, guaranteeing the right of opposition of the interested parties, which must be explicitly mentioned to the interested party and presented clearly and separately from any other information, no later than at the time of the first communication with the interested party (Article 21.4 GDPR).

In procedure PS/00078/2021, we stated regarding the absence of the requirement of balancing the following:

Due to the lack of information regarding the proof of balancing, the interested party is deprived of their right to know the legal basis for the processing claimed by the controller, and specifically, when referring to legitimate interest, they are deprived of their right to know what those legitimate interests alleged by the controller or a third party would be that would justify the processing without taking their consent into account.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/22

In the same way, the interested party is deprived of their right to argue why the alleged legitimate interest claimed by the responsible party could be countered by the rights or interests of the interested party. Since the interested party has not been given the opportunity to present these arguments to the responsible party, any balancing carried out by the responsible party without taking into account the circumstances that the interested party could have alleged, and which they have not been allowed to do, would be flawed, as it would be an act contrary to an imperative norm.

It is difficult to accept that processing is based on the legitimate interest of the responsible party when such processing is carried out covertly.

Therefore, it is not possible to invoke this legal basis of legitimate interest in the context of an administrative procedure, such as the transfer of the complaint or the allegations regarding the opening of the sanctioning procedure. Accepting this would be tantamount to admitting a subsequent legitimate interest, or a posteriori, regarding which the requirements established in the personal data protection regulations have not been respected and about which interested parties are not informed. And in relation to the requirement of "necessity," the resolution refers to it in the following terms:

Regarding the second of the requirements, however, it is considered that the processing of personal data carried out by MARINS PLAYA is not necessary or strictly necessary for the satisfaction of the alleged legitimate interest (the cited ruling of 04/05/2017, C-13/16, Rigas Satskime, in its paragraph 30, states: "As for the requirement that the processing of data be necessary, it should be recalled that exceptions and restrictions to the principle of protection of personal data must be established without exceeding the limits of what is strictly necessary").

This principle, according to which processing must be strictly necessary for the satisfaction of the legitimate interest, must be interpreted in accordance with what is established in Article 5.1.c) of the GDPR, which refers to the principle of data minimization, stating that personal data shall be "adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed." In this way, less invasive means should always be preferred to serve the same purpose. Necessity here implies that the processing is essential for the satisfaction of the aforementioned interest, so that if this objective can be reasonably achieved in another way that has less impact or is less intrusive, the legitimate interest cannot be invoked.

Thus, according to these criteria, this basis of legitimization could not be appreciated when the circumstances outlined do not occur, to which should be added the criterion of our jurisprudence, previously mentioned regarding the processing of the personal phone number of the worker or their personal email address for the purpose of maintaining the employment relationship, which consists of the fact that when they are essential for the performance of the contract, both must be provided by the company to the worker in order not to break the necessary alienation of the means that characterizes the employment contract. The requirement of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/22

The contribution of these means by the worker could imply a manifest abuse of business rights, as derived from the SAN of February 6, 2019.

Having established the above and focusing on the infringement being examined – breach of the duty of confidentiality – it is necessary first to analyze whether the creation of the WhatsApp group

“***GRUPO.1” in 2019 with the personal phone numbers of 5 workers for matters related to the training of these workers can be justified under any of the examined bases of legitimacy. In this regard, the responding party states that the workers agree with the established communication channels, participating in them, and that the names of the individuals who signed the complaint do not match the names of the group members. Hence, in this case, it is appropriate to bring to mind the doctrine of the Audiencia Nacional established, among others, in the SAN of June 13, 2017, and SAN of June 26, 2020, which considers it necessary to appreciate the existence of an infringement due to lack of consent that the affected party themselves must deny, as consent is personal and individual.

Therefore, the imposition of a sanction for the facts narrated is not warranted since none of the chat members have indicated the absence of consent.

On the contrary, it must be declared that the principle enshrined in Article 5.1.f) of the GDPR has been violated by the responding party's sending of two emails without using the blind carbon copy option, revealing the complainant's email address to the other recipients without their consent and without any other applicable basis of legitimacy from Article 6 of the GDPR.

Consequently, taking into account the considerations presented, it cannot be concluded that the responding entity had a basis of legitimacy that justified the disclosure of the complainant's personal email address. Therefore, this Agency considers that providing personal data to third parties, such as an email address, without a basis of legitimacy constitutes a breach of confidentiality that contravenes the principle of integrity and confidentiality set forth in Article 5.1.f) of the GDPR.

In light of these facts, the responding entity, by sending the email without using the BCC option, has infringed Article 5.1.f) of the GDPR.

IV

Classification and qualification of the infringement of Article 5.1.f) of the GDPR

The principles relating to the processing of personal data are regulated in Article 5 of the GDPR, which establishes that “personal data shall be:

a) processed lawfully, fairly, and transparently in relation to the data subject (“lawfulness, fairness, and transparency”);

b) collected for specified, legitimate, and explicit purposes, and shall not be further processed in a manner that is incompatible with those purposes; in accordance with Article 89, paragraph 1, further

processing of personal data for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes shall not be considered incompatible with the initial purposes ("purpose limitation");

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/22

c) adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed ("data minimization");

d) accurate and, where necessary, kept up to date; all reasonable measures will be taken to ensure that personal data that is inaccurate is erased or rectified without delay, with respect to the purposes for which it is processed ("accuracy");

e) maintained in a manner that allows for the identification of data subjects for no longer than is necessary for the purposes of processing personal data; personal data may be retained for longer periods as long as it is processed solely for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes, in accordance with Article 89, paragraph 1, without prejudice to the application of appropriate technical and organizational measures imposed by this Regulation to protect the rights and freedoms of the data subject ("storage limitation");

f) processed in a manner that ensures an adequate level of security for personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ("integrity and confidentiality").

The data controller shall be responsible for compliance with the provisions of paragraph 1 and be able to demonstrate it ("proactive accountability").

A breach of Article 5.1 f) of the GDPR may be subject to a fine of up to €20,000,000 or, in the case of an enterprise, an amount equivalent to 4% of the total global annual turnover of the previous financial year, opting for the higher amount, in accordance with Article 83.5 a) of the GDPR, which states as an infringement "the breach of the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9."

Article 72.1 a) of the LOPDGDD states that "in accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall prescribe after three years, which involve a substantial breach of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679."

V

On the infringement of Article 32 of the GDPR

As highlighted in legal basis II, the identification of a security breach does not directly imply the imposition of a sanction by this Agency, as it is necessary to analyze the diligence of controllers and processors and the security measures applied.

The examination of the documentation in the file does not allow for the appreciation of diligent behavior on the part of the respondent, who sent two communications to a plurality of recipients without concealing the addresses.

The respondent has not been able to justify that there were adequate security measures in place to ensure the confidentiality of the data in the mailings.

Furthermore, by sending communications to the personal email of employees without using blind carbon copy, it implies that the security measures of the respondent are not adequate to data protection regulations.

In accordance with the available evidence, it is considered that the known facts constitute an infringement, attributable to the respondent, for violation of Article 32 of the GDPR.

VI

Classification and qualification of the infringement of Article 32 of the GDPR

The security of personal data processing is regulated in Article 32 of the GDPR, which establishes the following:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probability and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data promptly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/22

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data can only process such data in accordance with the instructions of the controller, unless required to do so by Union law or the law of the Member States.”

It should be noted that the GDPR in the cited provision does not establish a list of security measures applicable according to the data being processed, but rather states that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity to the rights and freedoms of the data subjects.

In this regard, it should be noted that there are tools available in the market that reduce the risk of mistakenly sending emails to multiple recipients without using the blind carbon copy option, by keeping recipients hidden by default.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of the technical and organizational measures should be made taking into account: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification (which is not an audit), assessment, and evaluation of the effectiveness of the measures. In any case, when assessing the adequacy of the level of security, particular attention shall be paid to the risks presented by the processing of data, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial damage.

In the case at hand, the respondent, by sending an email without using the blind carbon copy option, is failing to comply with their obligation to apply appropriate technical and organizational measures to ensure an adequate level of security in the processing of personal data as set out in Article 32 of the

GDPR, especially considering that there are tools available in the market that reduce the risk of mistakenly sending emails to multiple recipients without using the blind carbon copy option. Article 83.4 of the GDPR establishes that administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the previous financial year, shall be imposed, opting for the higher amount when the following obligations are violated:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/22

Article 73 of the LOPDGDD, under the heading “Serious infringements for the purposes of limitation,” states:

“Based on Article 83.4 of Regulation (EU) 2016/679, the following infringements shall be considered serious and shall be subject to a limitation period of two years, which involve a substantial breach of the articles mentioned therein, and in particular the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

g) The breach, as a result of a lack of due diligence, of the technical and organizational measures that should have been implemented in accordance with the requirements of Article 32.1 of Regulation (EU) 2016/679.”

VII

On the powers of the supervisory authorities

Article 58.2 of the GDPR provides as follows: “Each supervisory authority shall have all of the following corrective powers:

d) to order the controller or processor to bring processing operations into compliance with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time;

i) to impose an administrative fine in accordance with Article 83, in addition to or instead of the measures mentioned in this section, depending on the circumstances of each particular case;

VIII

Sanction

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR.

Therefore, it is appropriate to calibrate the sanction to be imposed according to the criteria established in Article 83.2 of the GDPR, and in accordance with the provisions of Article 76 of the LOPDGDD, regarding section k) of the aforementioned Article 83.2 GDPR.

Article 83.2 of the GDPR states that:

“Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for those contemplated in Article 58, paragraph 2, letters a) to h) and j).

In deciding to impose an administrative fine and its amount in each individual case, due consideration shall be given to:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/22

a) the nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damages they have suffered;

- b) the intent or negligence in the infringement;
- c) any measures taken by the data controller or processor to mitigate the damages suffered by the affected parties;
- d) the degree of responsibility of the data controller or processor, considering the technical or organizational measures they have applied under Articles 25 and 32;
- e) any previous infringements committed by the data controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the data controller or processor reported the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58(2) have been previously ordered against the data controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42; and
- k) any other aggravating or mitigating factors applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.

In this case, this Agency maintains as an aggravating circumstance the one contemplated in Article 83.2(b) of the GDPR, the intent or negligence in the infringement, although it does not consider the existence of intent in this case but rather a clear lack of diligence on the part of the entity being complained against.

The balance of such circumstance outlined in Article 83.2(b) of the GDPR, regarding the infringement committed by violating the provisions of Article 5.1(f), allows for the imposition of a fine of €10,000 (ten thousand euros), and regarding the infringement committed by violating the provisions of Article 32 of the GDPR, allows for the imposition of a fine of €5,000 (five thousand euros).

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

21/22

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on ILUNION SEGURIDAD, S.A., with NIF A78917465,

- for an infringement of Article 5.1(f) of the GDPR, classified under Article 83.5 of the GDPR, a fine of €10,000 (ten thousand euros).

- for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a fine of €5,000 (five thousand euros).

SECOND: TO NOTIFY this resolution to ILUNION SEGURIDAD, S.A.

THIRD: To warn the sanctioned party that they must pay the imposed fine once this resolution becomes enforceable, in accordance with the provisions of Article 98.1(b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, to the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. In the absence of payment, collection will proceed in the executive period.

Upon receipt of the notification and once it is enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of

the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3(a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/22

If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the precautionary suspension to be concluded.

938-181022

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es